

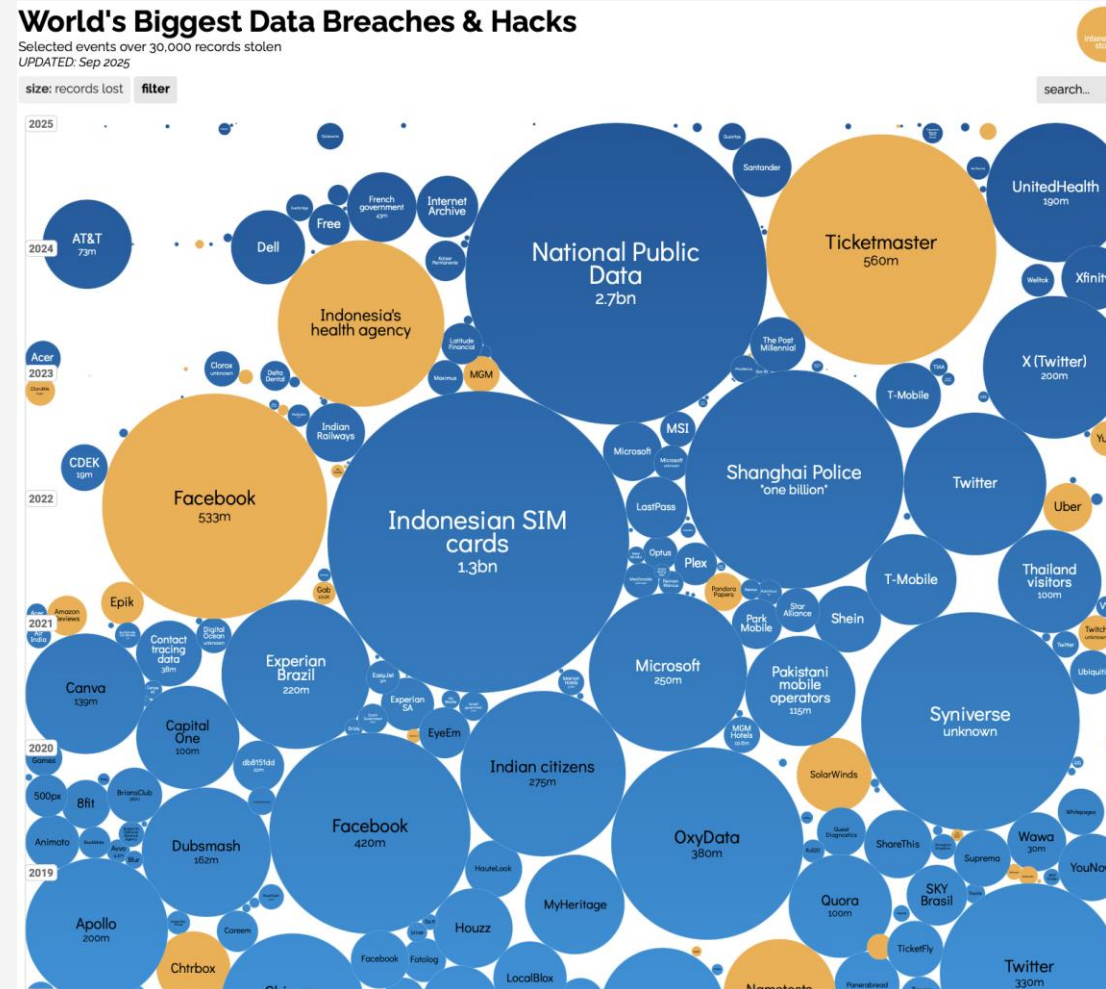


Security - Session 1: Introduction

Prof. Dr.-Ing. Sebastian Schlesinger
Professor of Business Computer Science
(Infrastructure & Security)

“Why is IT security even relevant?”

World's biggest data breaches and hacks

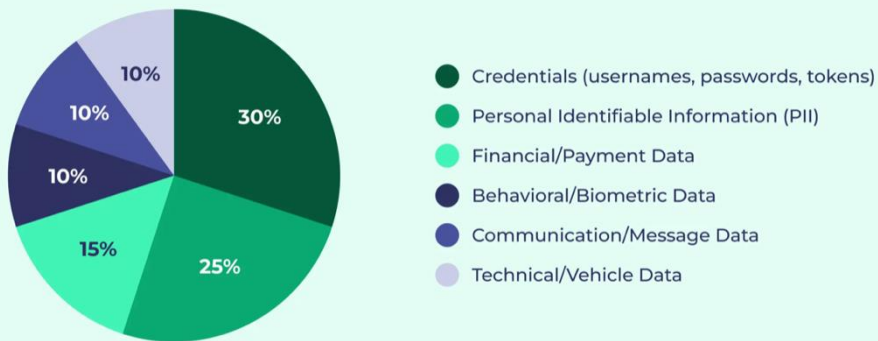


Source: <https://informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/>

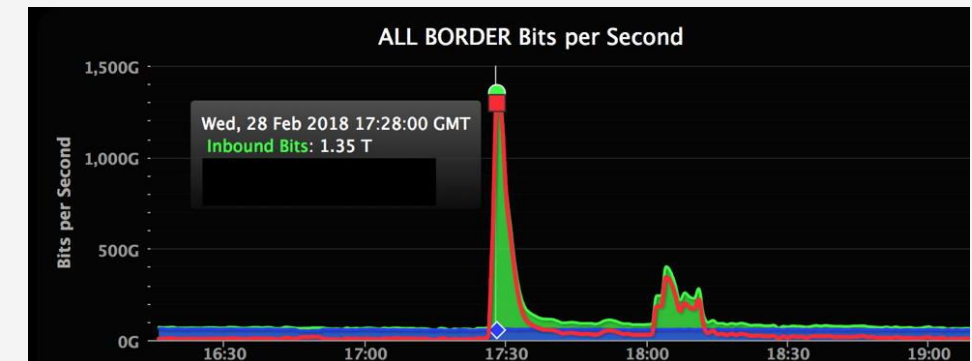


Relevanz IT Sicherheit

Distribution of Data Types Exposed (2025)

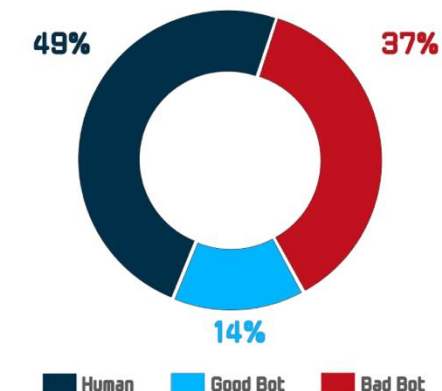


Distributed Denial of Service (GitHub 2018)



Global Internet Traffic 2025

Human vs Good Bot vs Bad Bot
Traffic



“What is IT security?”



“Computer security deals with the prevention and detection of unauthorized actions by users of a computer system.”

Ross J. Anderson: “Security Engineering”, Wiley, 2008



Setting the Scene

*How do
we know?*

*What are we
looking for?*

“Computer security deals with the **prevention and detection** of **unauthorized actions** by users of a computer **system**.”

Ross J. Anderson: “Security Engineering”, Wiley, 2008

*What is unauthorized?
Who decides?*

What is a system?



Setting the Scence

Security

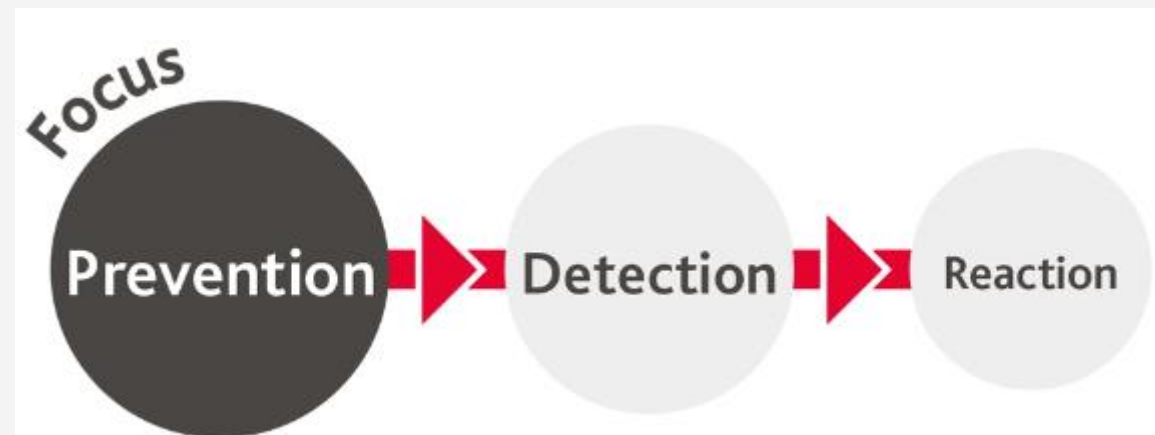
- Protection of assets
 - Assets: hardware, software, data, information, ...
 - Risks: malware, hackers, info leaks, ...
- Technical, economical & legal aspects



Risk Mitigation Strategies

Protection

- Prevention
 - Measures to prevent assets from being damaged (compromised, modified, ...)
- Detection
 - Measures to reveal and understand damage
- Reaction
 - Measures to recover assets from damage





Delineation to other related areas

Security

- Prevention and detection of unauthorized actions in a system

(intelligent) adversary

*accidents &
external circumstances*

Safety

- Warding off catastrophic consequences on users and systems

↳ Verification and Validation

Reliability

↳ e.g. Site Reliability Engineering

- Continuity of correct service in the face of system failures



IT Security Protection Goals

Security Targets

- Confidentiality

*Password leaks
Revelation of secret documents
Industrial espionage*

- Protect assets from unauthorized access and information from leakage

- Integrity

- Protect assets from being modified or irrational

*Creation of fake accounts
Manipulating databases
Interfering automated factory*

- Availability

- Protect asset from downtime

Denial of Service



IT Security Protection Goals

Security Targets

- **Confidentiality**
 - Protect assets from unauthorized access and information from leakage
- **Integrity**
 - Protect assets from being modified or irrational
- **Availability**
 - Protect asset from downtime





IT Security Protection Goals

Security Targets – there's more...

- Accountability
- Anonymity
- ...

Security Threats

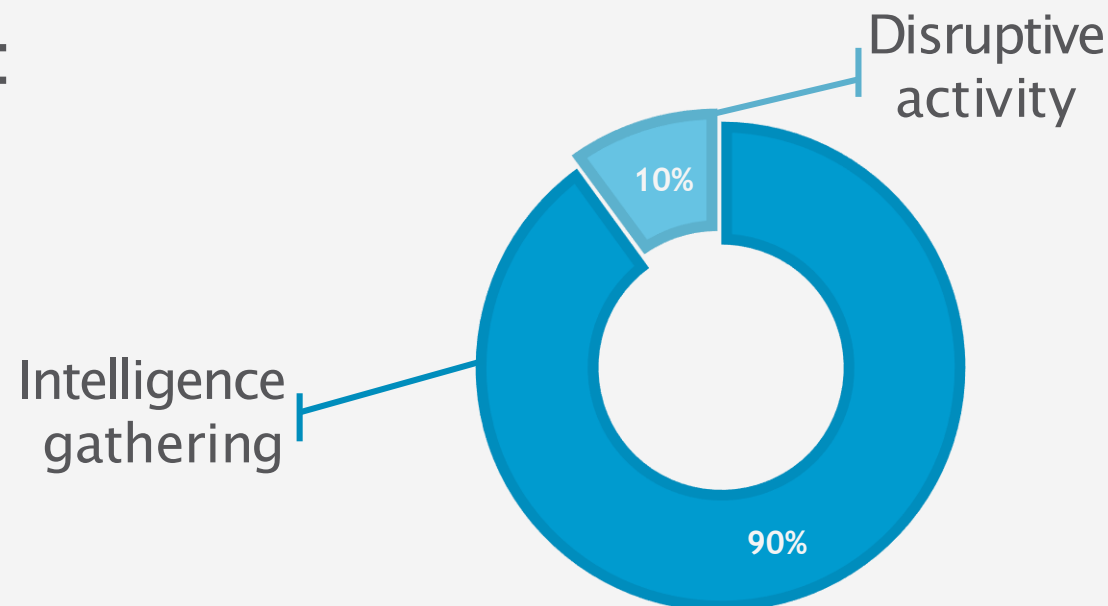
„What are threats to information technology?“



Security Threats

Targeted Attacks

- Specific target (server, organizations, ...)
- Attempt to compromise single system
- Defined goal:





Security Threats

Targeted Attacks

- Specific target (server, organizations, ...)
- Attempt to compromise single system
- Defined goal
- Examples: targeted hacking, spear phishing, social engineering, ...

*Zero-day bugs,
Advanced Persistent
Threats*

e-mail

multimodality



Security Threats

Multi-Targeted Attacks

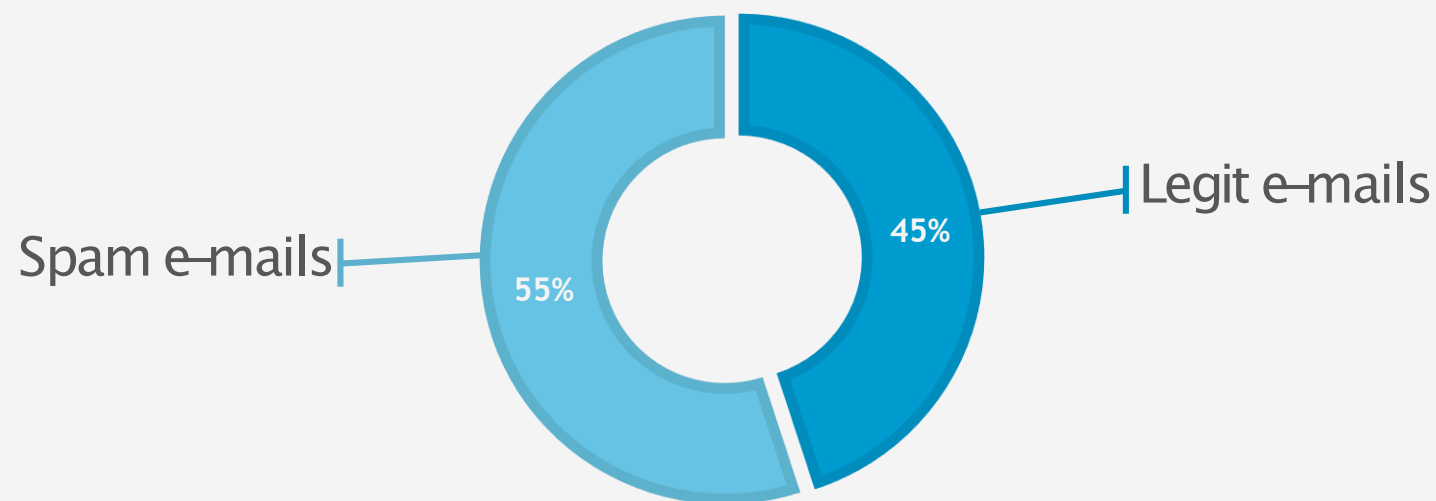
- Multiple targets
- Attempt to compromise many (heterogeneous) systems
- Automated, e.g., by malware
- Manifold goals
- Examples: spam, coin-mining, ...



Security Threats

Spam

- Unsolicited bulk e-mails
- Mostly commercial, e.g., pharmacy
- Partly malicious, e.g., scams





Security Threats

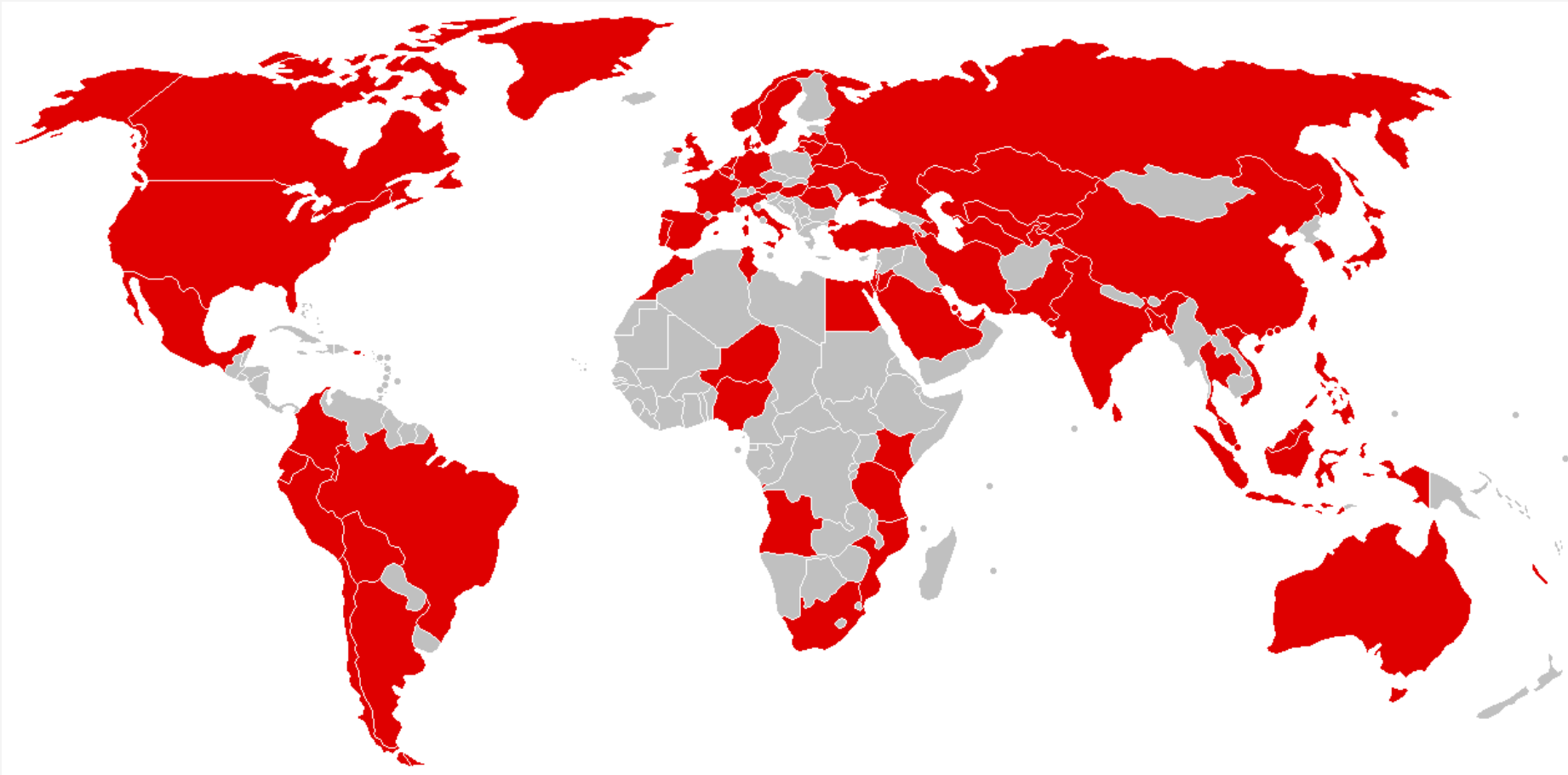
Ransomware

- Encrypt victims' systems completely
- No use of system possible
- Decryption key in exchange for money
- Blackmailing approach
- Malware
- Compromises *Availability*



Security Threats

Ransomware: WannaCry





Security Threats

Malware

Malicious Software

“software designed to cause damage on purpose”

viruses, worms, Trojan horses, ransomware,
spyware, adware, scareware, coin miners, ...



Security Threats

Malware on IoT Devices

- Internet of Things: networked „smart“ devices

KEY NUMBERS

(Updated August 2025)



46%

RANSOMWARE
INCREASE



12,000+

NEW RANSOMWARE
VARIANTS



50%

OT ATTACKS
IN SEC REPORTS



820,000

DAILY IoT
ATTACKS

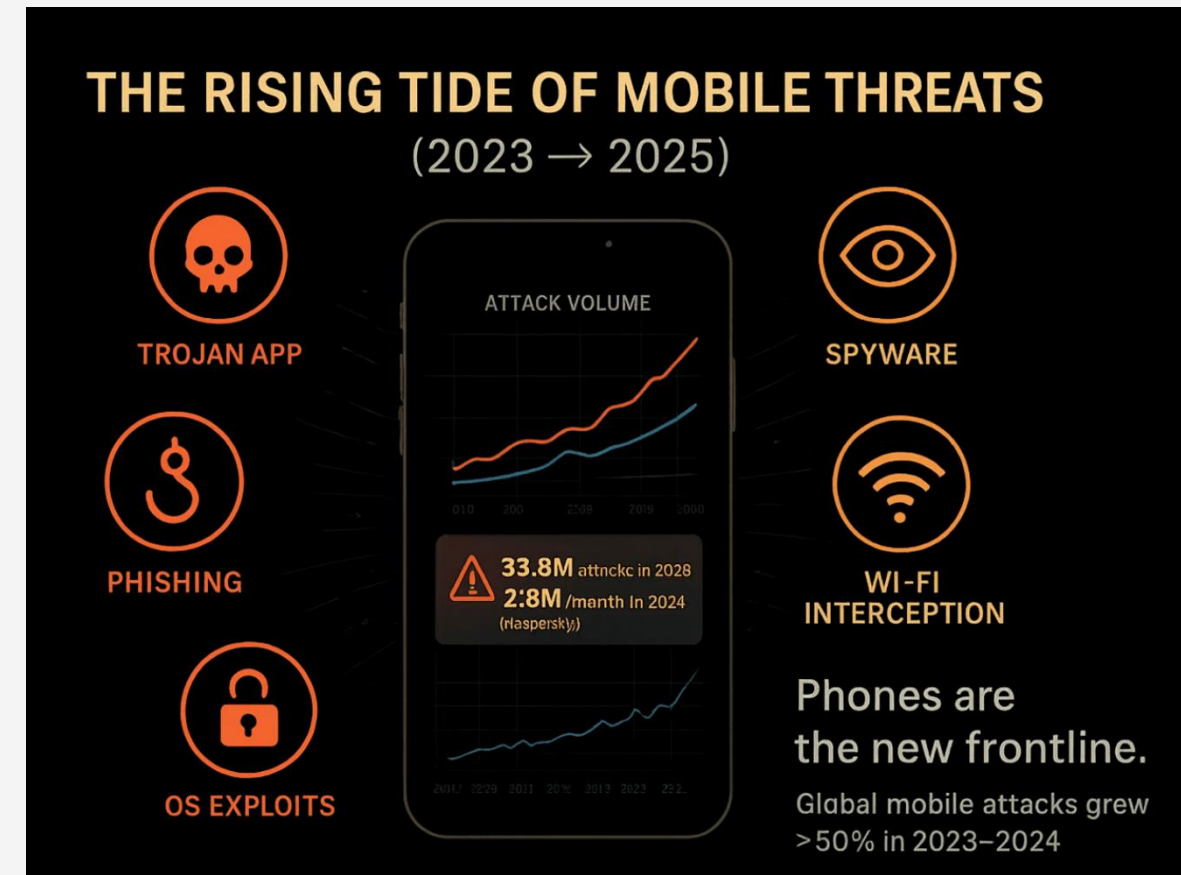
Key IoT hacking statistics defining the
2025 threat landscape



Security Threats

Mobile Malware

- Increasing threat since years
- Main flaw: old operating systems





Security Threats

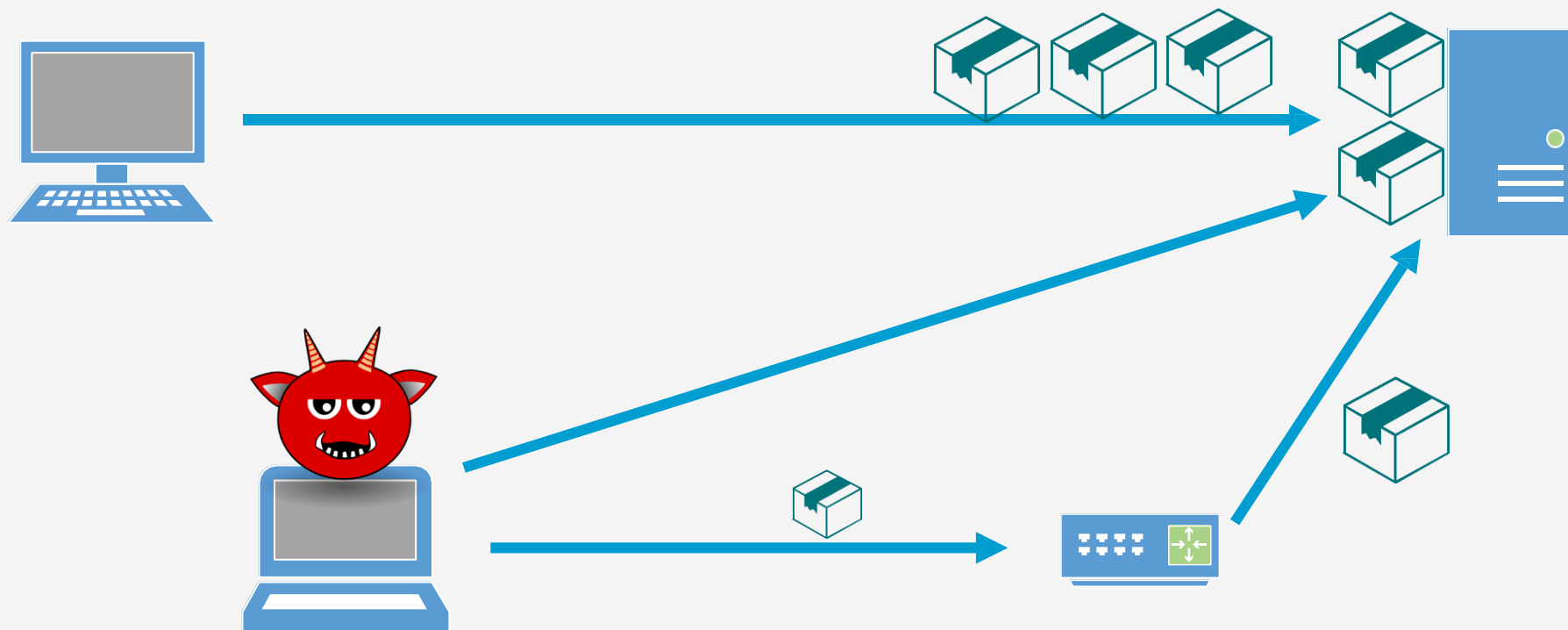
Software Bugs

- Vulnerability that allows
 - Unauthorized access
 - Faulty authentication
 - Information leakage
 - Data modification
- Caused by
 - Faulty implementations
 - Missing use case analyses
 - Unforeseen circumstances



Security Threats

Denial of Service





Security Threats

Denial of Service

- Flooding a victim system with requests
- Usually several attacker systems
- Optional amplification
 - Main flaw: IP spoofing
- Compromises Availability



AI for Cybersec (Blue Team)



Threat Detection.

AI analyzes data in real-time to detect patterns and anomalies, identifying potential cyber threats.



Incident Response.

AI automates and speeds up response to attacks, suggesting remediation steps to mitigate damage.



Vulnerability Management.

AI identifies weak points in networks, allowing businesses to focus on securing critical vulnerabilities.



Predictive Analytics.

AI predicts future threats by analyzing historical data and patterns, enabling proactive defenses.



Endpoint Protection and Malware Detection.

AI detects unusual behaviors and flags malware, including zero-day exploits.



Fraud Detection and Prevention.

AI analyzes transactions in real time, identifying suspicious activities to prevent fraud.



Cyber Asset Attack Surface Management (CAASM).

AI tracks and monitors where data is stored or transferred, enhancing network security.



Cloud Security.

AI secures cloud environments by offering real-time protection against threats, crucial for remote and hybrid work setups.



Agentic AI in Cybersecurity: The Double-Edged Sword

EMERGING THREATS



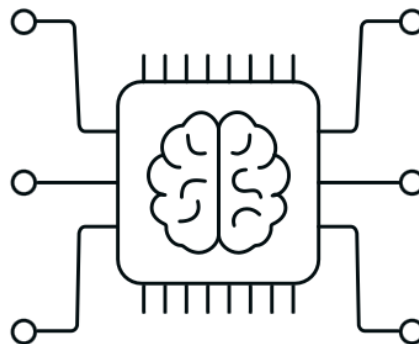
Autonomous
malware and
adaptive attacks



AI-accelerated
social engineering



Loss of control and
runaway agents



UNLOCKING OPPORTUNITIES



Automated threat
detection and
response



Proactive defense
simulations



AI-on-AI defense and
countermeasures

Cybersec Skills Gap

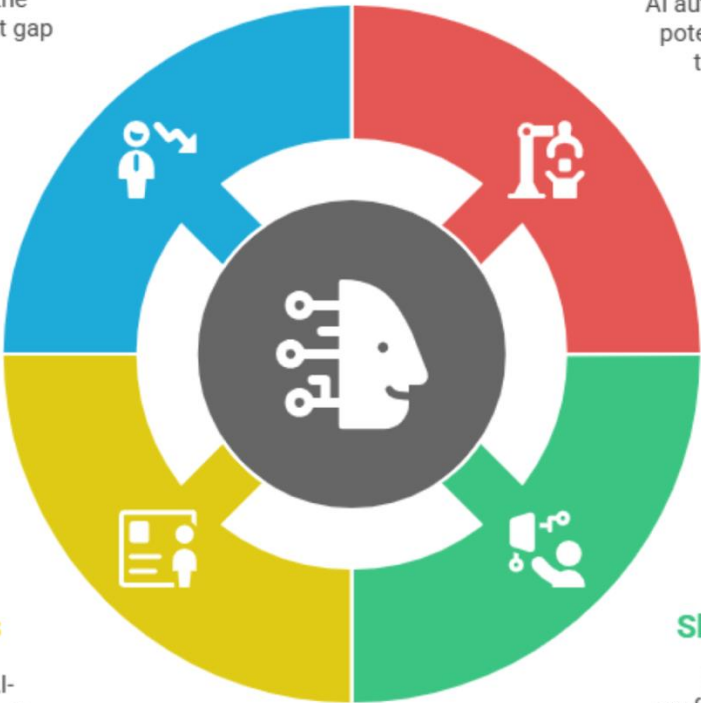
AI's Impact on Cybersecurity Jobs

Talent Shortage Mitigation

AI helping to fill the cybersecurity talent gap

Job Displacement

AI automation leading to potential job losses in traditional roles



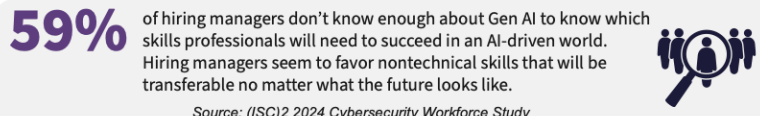
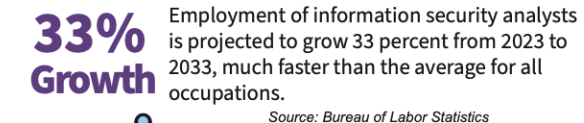
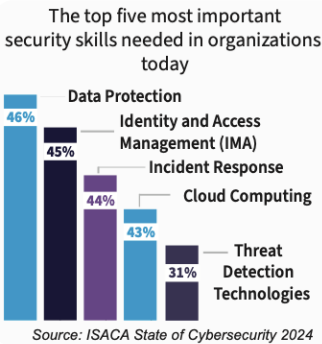
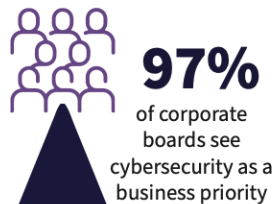
New Roles

Emergence of AI-focused cybersecurity positions

Skill Evolution

Cybersecurity professionals needing AI and data science skills

Cybersecurity Workforce Demand



Some of the most pressing issues in 2025

The Sentinel's Gaze: Cybersecurity in 2025



THREAT LANDSCAPE	AI IN SECURITY	QUANTUM THREATS	HUMAN FACTOR	REGULATIONS & ETHICS
				
• Ransomware • Supply Chain Attacks	• AI Defenses • AI Threats	• Quantum Computing • PQC	• Social Engineering • Insider Risk	• Compliance • Ethical AI
				COE SECURITY

AI Security Risks

A large percentage of organizations are exposed to AI security risks.



Figure 1 - AI Security Exposures

*Data based on 2024–2025 global reports from Cyberhaven, Swimlane, FISAC, Capgemini, Palo Alto Networks, and Pillar Security analyzing AI security incidents across sectors.



Cybersec Threats 2025

OWASP Top 10 for LLM Applications: 2023 vs. 2025

LLM 01
Prompt Injection

LLM 02
Sensitive Information
Disclosure

LLM 03
Supply Chain

LLM 04
Data and Model
Poisoning

LLM 05
Improper Output
handling

REVAMPED
LLM 06
Excessive Agency

NEW!
LLM 07
System Prompt
Leakage

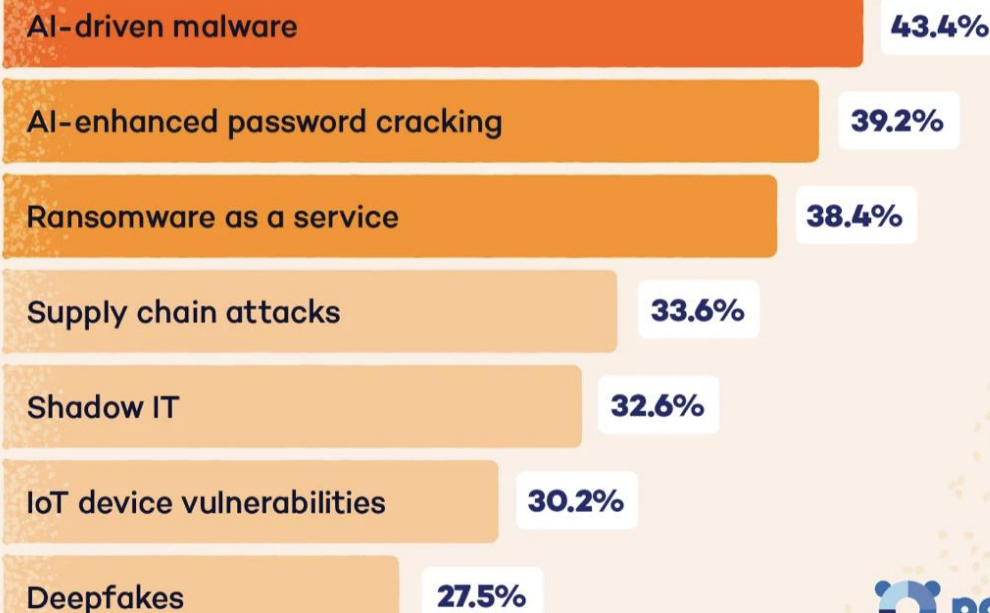
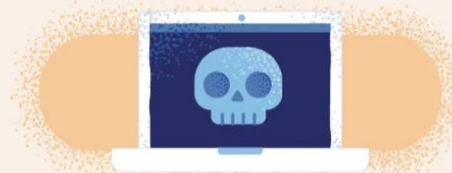
NEW!
LLM 08
Vector & Embedding
Weaknesses

REVAMPED
LLM 09
Misinformation

REVAMPED
LLM 10
Unbounded
Consumption



Top Cybersecurity Threats of 2025



Challenges of IT Security



Hochschule für
Wirtschaft und Recht Berlin
Berlin School of Economics and Law

*“What are some examples
for hacks?”*

XSS

Safari File Edit View History Bookmarks Develop Window Help

Not Secure — 18.158.123.224/#/search

Instances | EC2 Management Console Running OWASP Juice Shop - Pausing OWASP Juice Shop OWASP Juice Shop

OWASP Juice Shop

Account EN

The server has been restarted: Your previous hacking progress has been restored automatically. [Delete cookie to clear hacking progress](#)

You successfully solved a challenge: Score Board (Find the carefully hidden 'Score Board' page.)

All Products

Product Image	Product Name	Price
	Apple Juice (1000ml)	1.99a
	Apple Pomace	0.89a
	Banana Juice (1000ml)	1.99a
	Carrot Juice (1000ml)	2.99a
	Eggfruit Juice (500ml)	8.99a
	Fruit Press	89.99a
	Green Smoothie	1.99a
	Juice Shop Adversary Trading Card (Common)	2.00a

This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!

[Me want it!](#)



Server-Side Request Forgery (SSRF)

SSRF-vulnerable code

```
<?php

/**
 * Check if the 'url' GET variable is set
 * Example - http://localhost/?url=http://testphp.vulnweb.com/images/logo.gif
 */
if (isset($_GET['url'])){
    $url = $_GET['url'];

    /**
     * Send a request vulnerable to SSRF since
     * no validation is being done on $url
     * before sending the request
     */
    $image = fopen($url, 'rb');
```

Exploits

```
GET /?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1
Host: example.com
```

```
GET /?url=file:///etc/passwd HTTP/1.1
Host: example.com
```

- Missing input validation
- We'll get to that in the Application Security section

Security Threats



Hochschule für
Wirtschaft und Recht Berlin
Berlin School of Economics and Law



Challenges of IT Security



Hochschule für
Wirtschaft und Recht Berlin
Berlin School of Economics and Law

“Why is Security difficult?”



Some Challenges

- “Security is not important”
- “IT Security team prevents instead of enabling”
- “Security is a process” (Bruce Schneier)
- Security is not tangible and hard to understand
- Developers think in terms of user stories, security needs to think in terms of abuser stories
- Complexity stack vs. details on lower levels
- Each system has specific vulnerabilities (operating systems, applications, programming languages etc.)
- Complex systems that interact with each other in manner hard to reproduce
- Hard to incorporate into software development lifecycle
- Security vs. Usability
- Flood of security news
- Connectivity
- Zero day exploits



Particular Challenges for Network Security

- Remote accessibility
- Distribution of attacks
- (perceived) anonymity
- High complexity
- Supply Chain Attacks hard to track



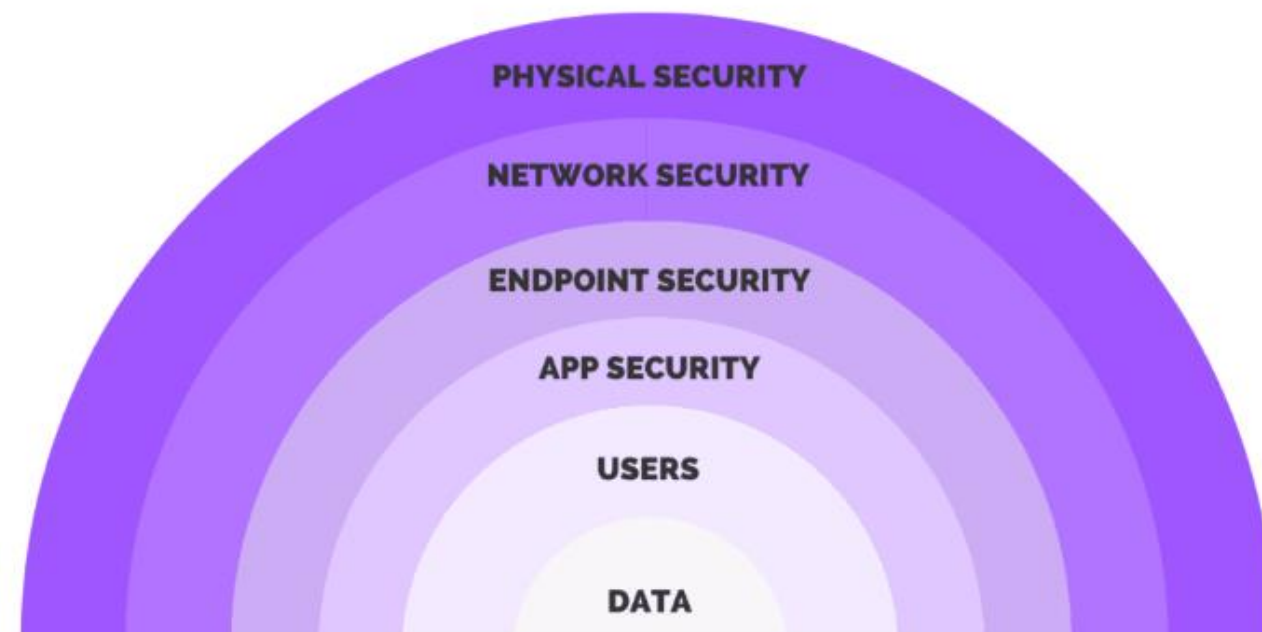
Particular Challenges for Embedded Security

- Low Level implementation, hard to track security issues
- Irregular security updates: either underestimated security threats or due to low bandwidth / decentral application irregular updates
- Mass production of embedded devices → attack replication
- Dependability / ubiquitousness of embedded devices, particularly for critical infrastructure
- Longer device lifecycle compared to traditional IT
- ...



Some general remarks on security

- There is no perfect security, every system is hackable
- As always, people, processes, and technology are key
- People often are the greatest weakness
- Security is a company-wide challenge and effort
- Security processes happen in iterative cycles – it is often a cat and mouse game
- Since there is no silver bullet, security approaches are generally applied in layers, in an onion-like design
- Hacking is a lot about trial and error and questioning the assumptions the software engineers have made
- We are developing on top of a huge stack of complexity and abstraction; Security has a lot to do with decoupling that complexity and understanding what's really going on under the hood





Some foundational vocabulary

Threats



Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service. Also, the potential for a threat-source to successfully exploit a particular information system vulnerability.

Example

External attacker tries to gain access to sensitive data

Source: NIST glossary



Vulnerability



Hochschule für
Wirtschaft und Recht Berlin
Berlin School of Economics and Law

Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.

Example

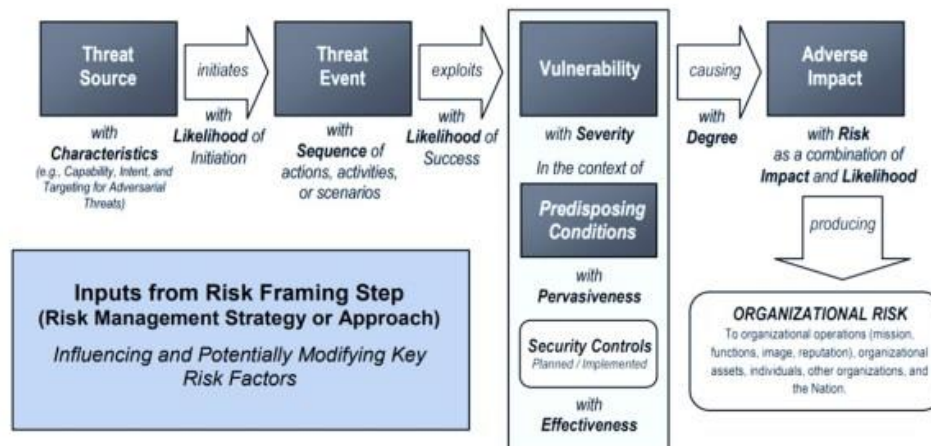
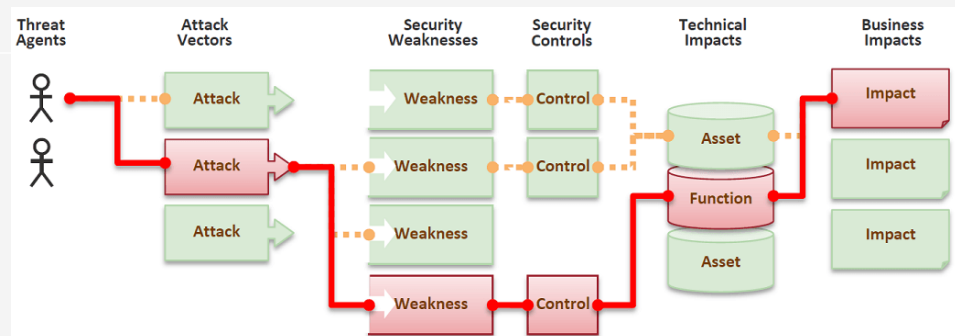
Data in an S3 bucket is unencrypted

Source: NIST glossary

Risk



The level of impact on organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals resulting from the operation of an information system given the potential impact of a threat and the likelihood of that threat occurring.



		Consequence				
		Negligible 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
Likelihood	5 Almost certain	Moderate 5	High 10	Extreme 15	Extreme 20	Extreme 25
	4 Likely	Moderate 4	High 8	High 12	Extreme 16	Extreme 20
	3 Possible	Low 3	Moderate 6	High 9	High 12	Extreme 15
	2 Unlikely	Low 2	Moderate 4	Moderate 6	High 8	High 10
	1 Rare	Low 1	Low 2	Low 3	Moderate 4	Moderate 5

Source: NIST glossary

Security Risk Ontology

